

interface they are able to use the application without privileges.

Another case of such vulnerability might exist if the web site simply checks if the user is logged in, but doesn't check the authorisation level. For example, a CMS might show or hide links to certain features, such as editing articles and uploading files depending on the user's level of access; however simply showing and hiding such links is not enough if the user can simply type the URL and access these features. Each page to check whether the current user is authorised to access it instead of just relying on the absence of links to the interface as a deterrent.

The role of the user using the web site should be considered by the web site instead of a simple binary logged in / logged out check.

3.2.10 Insufficient transport layer protection

"Applications frequently fail to authenticate, encrypt, and protect the confidentiality and integrity of sensitive network traffic. When they do, they sometimes support weak algorithms, use expired or invalid certificates, or do not use them correctly."

As was made clear earlier, simple encryption isn't enough, the encryption itself needs to be secure. However often times, sensitive information being transmitted by the browser is not encrypted at all.

It is remarkable how much information can be tapped by simply using application such as Wireshark to listen in to network traffic. Any and all content which is transmitted without encryption is as good as public knowledge. If any password is being transmitted without SSL encryption to the server, it doesn't matter how well it is hashed in the server, with how much salt, an attacker can simply listen in and get the password – or other secure information – in transit.

A website needs to ensure that any webpage that requires authentication, or is required to transmit private secure data such as credit card numbers is sufficiently secured with a VALID SSL certificate.

3.2.11 Unvalidated redirects and forwards

"Web applications frequently redirect and forward users to other pages and websites, and use untrusted data to determine the destination pages. Without proper validation, attackers can redirect victims to phishing or malware sites, or use forwards to access unauthorized pages."

This is again a pretty straightforward exploit. Consider a web site that uses a redirect script to transfer users to another external site. This gives phishers a considerable boost, as they can use the original domain name to gain some authenticity.

So for a social networking website which has a redirect page:

<http://www.youttwitface.com/redirect.php?url=http://www.totallyevilsite.com>